

Procédure de Gestion des Incidents de Sécurité — TechShop SAS

Version : 1.0
Date : Juin 2026
Auteur : Dorian Poncelet (Consultant GRC)
Validée par : Marie Laurent (DG) + Thomas Rivet (DSI)
Statut : Validé — Applicable immédiatement
Références : ISO 27001:2022 A.5.24–A.5.28 / NIS2 Art. 21(b) / RGPD Art. 33

Pourquoi cette procédure existe

Le 19 mars 2021, le datacenter OVH SBG2 à Strasbourg brûlait. Des milliers de PME françaises ont perdu leurs données cette nuit-là — non pas parce que OVH n'avait pas de plan, mais parce que leurs clients n'en avaient pas. Ils ne savaient pas quoi faire dans les premières heures.

Chez TechShop, notre dépendance à l'infrastructure numérique est totale. Une interruption de WooCommerce c'est zéro commande. Un ransomware c'est potentiellement la fin de l'activité. Cette procédure existe pour que, le jour où quelque chose arrive — et ce jour viendra — personne ne perde de temps à se demander qui appelle qui.

Contacts d'urgence

Rôle	Nom	Email	Téléphone
DSI — Responsable incident	Thomas Rivet	thomas.rivet@techshop.fr	06 XX XX XX XX
DG — Décision de crise	Marie Laurent	marie.laurent@techshop.fr	06 XX XX XX XX
DPO — Notification CNIL	Sophie Blanc	dpo@techshop.fr	06 XX XX XX XX
OVH Support urgence	—	support@ovhcloud.com	+33 9 72 10 10 07
AWS Support	—	aws.amazon.com/support	Console AWS
CERT-FR (signalement)	—	cert-fr.eu	cert.ssi.gouv.fr

Ces numéros doivent être affichés physiquement dans le bureau du DSI et dans la salle de réunion principale. Ne pas laisser cette information uniquement dans un document numérique potentiellement inaccessible lors d'une crise.

Classification des incidents

Niveau P1 — Critique

Définition : Le système d'information est compromis ou indisponible, avec impact direct sur l'activité ou les données clients.

Exemples :

- Ransomware actif sur les serveurs OVH
- Fuite de données clients confirmée (accès non autorisé à la BDD)
- Site WooCommerce indisponible depuis plus de 2 heures
- Compromission du compte admin Google Workspace

Délai de réponse initial : 1 heure maximum

Escalade : DSI -> DG -> DPO (si données personnelles)

Notification externe : CNIL sous 72h si données personnelles concernées (RGPD Art. 33)

Niveau P2 — Élevé

Définition : Incident avec impact potentiel sur la sécurité, sans compromission confirmée.

Exemples :

- Tentative d'intrusion bloquée par Cloudflare WAF (volume anormal)
- Employé ayant cliqué sur un lien de phishing
- Poste de travail avec comportement anormal (possible malware)
- Accès inhabituel à un compte (connexion depuis pays étranger)

Délai de réponse initial : 4 heures maximum

Escalade : DSI -> DG si dégradation vers P1

Niveau P3 — Modéré

Définition : Incident à faible impact immédiat, nécessitant une correction planifiée.

Exemples :

- Certificat TLS expiré sur un service secondaire
- Plugin WordPress avec CVE critique non encore patchée
- Compte d'un ex-employé encore actif découvert lors d'un audit
- Violation mineure de la charte informatique (usage personnel excessif)

Délai de réponse initial : 72 heures maximum

Escalade : DSI, traitement dans le cadre du plan de traitement normal

Procédure step-by-step

PHASE 1 — Détection et qualification (H+0 à H+1)

```
????????????????????????????????????????????????????????????
?  QUI PEUT DÉTECTER UN INCIDENT ?                                ?
?  -> N'importe quel employé ?                                    ?
?  -> Grafana / Prometheus (alertes automatiques)                ?
?  -> Cloudflare WAF (alertes email)                               ?
?  -> Un client qui signale quelque chose d'anormal               ?
????????????????????????????????????????????????????????????
```

Étape 1.1 — Signalement

Toute personne suspectant un incident envoie un email à **securite@techshop.fr** avec :

- Ce qu'elle a observé (description factuelle, pas d'interprétation)
- L'heure de la première observation
- Le système concerné
- Ce qu'elle a fait depuis (rien, ou elle a essayé de corriger)

Étape 1.2 — Qualification par le DSI

Thomas Rivet évalue dans l'heure :

- Est-ce un incident de sécurité ou un problème technique ?
- Quel est le niveau (P1 / P2 / P3) ?
- Des données personnelles sont-elles potentiellement exposées ?

Si P1 -> activation immédiate du mode crise (Phase 2).

Si P2 -> investigation approfondie (Phase 3 directement).

Si P3 -> traitement planifié, pas d'escalade.

Étape 1.3 — Ouverture du dossier incident

Pour tout incident P1 et P2, ouvrir une entrée dans le registre des incidents :

poc/cnil/registre-incident-001.md (template disponible)

PHASE 2 — Réponse d'urgence P1 (H+0 à H+4)

Playbook A — Ransomware

```
H+0  Alerte détectée (Grafana, employé, client)
?
H+0  ISOLATION IMMÉDIATE
    -> Couper le réseau du ou des serveurs compromis
        (OVH Manager : désactiver l'interface réseau du VPS)
    -> NE PAS RÉTENDRE les serveurs (préserve les preuves en mémoire)
?
H+15 Appel DSI -> DG (appel vocal, pas email)
    -> Décision : activer le PRA ?
?
H+30 Réévaluation de l'étendue
    -> Les sauvegardes S3 sont-elles intactes ? (vérifier Object Lock)
    -> Le backup le plus récent date de quand ?
    -> Combien de serveurs sont touchés ?
?
```

H+1 D?cision de la DG : payer la ran?on ou restaurer ?
(Ne jamais payer sans conseil juridique ? contacter un avocat sp?cialis?)
?

H+2 Si restauration : proc?dure PRA (smsi/05-plan-traitement/plan-traitement-risques.md)
-> Restauration depuis S3 Object Lock
-> RTO cible : 4 heures
?

H+4 Communication clients si service d?grad? (Marie Laurent d?cide du message)
?

H+24 Notification CNIL si donn?es personnelles expos?es (Sophie Blanc)
-> D?lai l?gal : 72h apr?s d?tection

Contacts imm?diats :

- OVH pour isoler les VPS : +33 9 72 10 10 07
- AWS pour v?rifier l'int?grit? S3 : Console AWS ou support
- ANSSI (si attaque sophistiqu?e) : cert.ssi.gouv.fr

Playbook B — Fuite de donn?es clients

H+0 D?tection (alerte WAF, signalement externe, d?couverte audit)
?

H+1 DSI + DPD qualifiant : combien de personnes concern?es ?
Quelles donn?es ? (email seul, adresse, donn?es bancaires ?)
?

H+2 Couper l'acc?s ? la source (d?sactiver endpoint API vuln?rable,
r?vocuer cl? compromis, bloquer IP suspecte sur Cloudflare)
?

H+4 ?valuation du risque pour les personnes concern?es
-> Risque faible (donn?es d?j? publiques) : pas de notification
-> Risque ?lev? (email + mot de passe) : notification CNIL obligatoire
-> Risque tr?s ?lev? (donn?es bancaires, RH) : notification CNIL + personnes concern?es
?

H+48 Pr?paration notification CNIL (Sophie Blanc)
-> Template : poc/cnil/notification-cnil-techshop.md
?

H+72 Notification CNIL (d?lai l?gal maximum ? Art. 33 RGPD)
-> Via notifications.cnil.fr

Playbook C — Compromission compte admin

H+0 D?tection (alerte connexion inhabituelle GW, employ? signale)
?

H+0 R?VOCATION IMM?DIATE
-> Google Workspace Admin : r?vocuer les sessions actives du compte
-> Changer le mot de passe du compte compromis
-> Si compte admin : d?sactiver temporairement
?

H+1 V?rification de l'?tendue
-> Quels services ont ?t? acc?d?s avec ce compte ?
-> Des donn?es ont-elles ?t? export?es ? (logs GW Activity)
-> Des r?gles de redirection email ont-elles ?t? cr??es ?
?

H+2 Revue de tous les comptes admin (autres comptes compromis ?)
?

H+4 Activation MFA forc?e sur tous les comptes si pas encore fait
?

H+24 Post-mortem : comment le compte a-t-il ?t? compromis ?
(phishing, credential stuffing, mot de passe faible...)

PHASE 3 — Investigation et containment (H+4 à H+48)

Une fois la crise immédiate stabilisée :

3.1 Préservation des preuves

Avant toute action de nettoyage :

- Snapshot des serveurs compromis (OVH Manager)
- Export des logs Grafana/Prometheus de la période concernée
- Export des logs Cloudflare WAF
- Export des logs d'activité Google Workspace
- Screenshot de tout ce qui peut disparaître

Ne pas nettoyer avant d'avoir les preuves. En cas de dépôt de plainte ultérieur, ces éléments sont indispensables.

3.2 Analyse des causes

- Par quel vecteur l'attaque est-elle entrée ?
- Quelles vulnérabilités ont été exploitées ?
- Depuis combien de temps l'attaquant était-il dans le système ?
- A-t-il laissé des backdoors ?

3.3 Remédiation

- Corriger la vulnérabilité exploitée avant de remettre le service en production
- Changer tous les mots de passe potentiellement exposés
- Vérifier l'intégrité des sauvegardes
- Faire un scan complet (WPScan, vérification fichiers modifiés)

PHASE 4 — Notification externe (selon classification)

Destinataire	Quand	Délai	Responsable
CNIL	Données personnelles exposées (risque élevé)	72h après détection	DPO — Sophie Blanc
ANSSI	Incident NIS2 significatif	24h (rapport initial), 72h (complet)	DSI + DG
Clients concernés	Risque très élevé pour les personnes	Dès que possible après CNIL	DG — Marie Laurent
Fournisseurs impactés	Si chaîne de valeur affectée	24h	DSI
Assurance	Si couverture cyber souscrite	Selon contrat	DG

Comment rédiger la notification CNIL

Le template est dans [poc/cnil/notification-cnil-techshop.md](#). Les 5 éléments obligatoires :

- Nature de la violation (quoi, comment, quand)
- Catégories et nombre approximatif de personnes concernées

- Catégories et nombre approximatif d'enregistrements concernés
- Conséquences probables de la violation
- Mesures prises ou proposées pour y remédier

PHASE 5 — Post-mortem et amélioration (J+7 à J+30)

Obligatoire pour tout incident P1, recommandé pour P2.

Le post-mortem n'est pas une réunion pour trouver des coupables. C'est une réunion pour comprendre ce qui s'est passé et éviter que ça recommence.

Structure du post-mortem (1h maximum) :

1. Chronologie factuelle (15 min)
 - > Qui a détecté ? quoi, ? quelle heure
 - > Quelles actions ont été prises, dans quel ordre
2. Analyse des causes (20 min)
 - > Cause immédiate (la vulnérabilité exploitée)
 - > Cause profonde (pourquoi cette vulnérabilité existait)
 - > Facteurs aggravants (pourquoi la détection a pris du temps)
3. Ce qui a bien fonctionné ? (10 min)
 - > Ne pas oublier de noter ce qui a bien marché
4. Actions correctives (15 min)
 - > Actions techniques immédiates
 - > Mises à jour de procédures
 - > Formation si pertinent
 - > Responsable + délai pour chaque action

Le compte-rendu est archivé dans [poc/cnil/](#) avec les autres incidents.

Registre des incidents

Chaque incident P1 et P2 est documenté dans le registre :

ID	Date de détection	Type	Niveau	Données personnelles	Notification CNIL	Clôture	Coût estimé
INC-001	03/06/2026	Simulation exercice	P1	Oui (fictif)	Simulée	03/06/2026	0€

Tests de la procédure

Cette procédure ne vaut rien si elle n'a jamais été testée.

Exercice	Fréquence	Prochain	Responsable
Exercice de crise ransomware (simulation)	Annuel	Avril 2027 (Audit A-04)	DSI + DG
Test restauration sauvegarde	Trimestriel	Septembre 2026	DSI
Test notification CNIL (simulation)	Annuel	Janvier 2027 (Audit A-03)	DPO
Vérification liste contacts d'urgence	Semestriel	Décembre 2026	DSI

Document classifié : CONFIDENTIEL — Accès : DSI, DG, DPO

Une version résumée (contacts d'urgence + classification) est affichée physiquement dans les bureaux

Prochaine révision : Décembre 2026 ou suite à incident P1